

ISO 27001 Certification-Readiness Self-Assessment

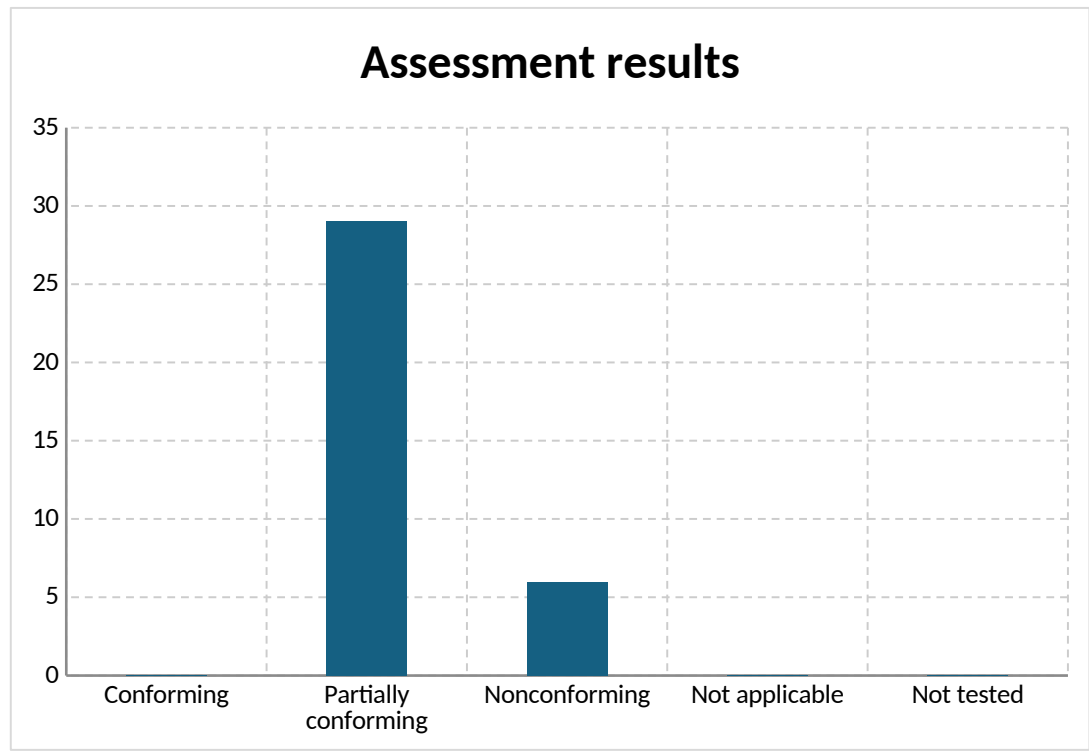
The Phone Boss ULTD | Point-in-time assessment | 09/13/2026

Assessment type	Owner-led certification-readiness self-assessment
Scope	Current ISMS documentation, practices and selected Annex A
Criteria	Paraphrased ISO/IEC 27001:2022 Clauses 4–10 and selected controls from the Statement of Applicability
Assessment owner	Richard Vincent
Independence limitation	The owner developed and assessed the ISMS. This is not an independent internal audit or certification audit.
Evidence basis	Current records, owner responses, and Projects 1–5. Draft documents are not treated as approved operating evidence.

Assessment results	Count
Conforming	0
Partially conforming	29
Nonconforming	6
Not applicable	0
Not tested	0

Readiness conclusion	
Conclusion	The Phone Boss ULTD has created core ISMS documentation and operates several practical security controls. However, the ISMS documents remain unapproved and no recurring governance cycle currently operates. The organization is not certification-ready at this
Priority 1	Formally approve the scope, context, risk register, Statement of Applicability and policy pack. Establish the recurring ISMS cycle.
Priority 2	Implement and retain evidence for objectives, treatment tracking, metrics, internal audit, management review and corrective actions.

Findings	Count
Major nonconformity	1
Minor nonconformity	12
Observation	1



Clauses 4–10 Checklist

Paraphrased audit criteria. Draft evidence does not establish operating effectiveness.

Clause	Area	Paraphrased requirement	Evidence to request	Testing procedure	Current assessment	Evidence reviewed	Result	Recommended action
4.1	Context	Identify internal and external issues relevant to the ISMS.	Draft context register; business and technology changes	Inspect register and confirm issues reflect actual operations.	Context register exists but is not formally approved.	Draft Project 2 context register	Partially conforming	Approve and review after material changes.
4.2	Context	Identify interested parties and their relevant security requirements.	Interested-party register; legal and contractual requirements	Check parties, requirements, owners and review triggers.	Interested parties and examples are documented in draft form.	Draft Project 2 register	Partially conforming	Approve register and validate current obligations.
4.3	Context	Define and maintain the ISMS scope.	Scope statement; boundaries; exclusions; dependencies	Confirm services, systems, locations, people and dependencies are covered.	Scope statement exists but remains a draft.	Draft Project 1 scope statement	Partially conforming	Formally approve and control the scope statement.
4.4	Context	Establish, implement, maintain and continually improve the ISMS.	Approved ISMS processes; recurring governance records	Trace the full plan-operate-evaluate-improve cycle.	No documented recurring ISMS cycle currently operates.	Owner response; Projects 1–5	Nonconforming	Approve the framework and establish an operating calendar.
5.1	Leadership	Demonstrate leadership commitment and integration with business activities.	Approvals; resources; review decisions; assigned actions	Inspect evidence of direction, resources and follow-up.	Owner actively developed the ISMS, but formal approval and reviews are pending.	Projects 1–5; owner response	Partially conforming	Approve the ISMS and document management decisions.
5.2	Leadership	Establish and communicate an information security policy.	Approved policy; communication evidence; review record	Confirm policy approval, availability and review cycle.	Policy pack is complete but pending approval.	Project 5 policy pack	Nonconforming	Sign and date the approval record; communicate applicable requirements.
5.3	Leadership	Assign and communicate ISMS responsibilities and authorities.	Role descriptions; responsibility matrix; approvals	Confirm accountability and reporting responsibility.	Responsibilities are described in draft policies but not formally adopted.	Project 5 policy pack	Partially conforming	Approve responsibilities and maintain a simple RACI or role register.
6.1	Planning	Address ISMS risks and opportunities.	Risk register; opportunity actions; planning records	Check completeness, ownership, actions and integration.	Risk work exists in draft form; opportunity planning is not formalized.	Project 3 risk register	Partially conforming	Approve the methodology and record relevant opportunities.
6.1.2	Planning	Use a consistent information security risk-assessment process.	Methodology; criteria; risk register; approvals	Reperform selected scores and confirm consistent criteria.	A scored risk register exists but has not been formally approved.	Project 3 risk register	Partially conforming	Approve the method and schedule reassessment.
6.1.3	Planning	Select treatments, document controls and obtain risk-owner approval.	Treatment plan; SoA; residual-risk approval	Trace risks to controls, actions and approval.	Treatment plan and SoA exist, but actions and residual risk are not formally closed.	Projects 3 and 4	Partially conforming	Track treatment evidence and record residual-risk decisions.
6.2	Planning	Set measurable security objectives and plans to achieve them.	Objectives register; targets; owners; due dates; results	Check that objectives are measurable and reviewed.	Objectives exist informally but are not documented or tracked.	Owner response	Partially conforming	Create and review a measurable objectives register.
6.3	Planning	Plan ISMS changes in a controlled manner.	Change assessment; approvals; implementation evidence	Sample material changes and trace security planning.	Website migration is known, but no formal ISMS change-planning record exists.	Owner response	Partially conforming	Add a lightweight security change-assessment record.
7.1	Support	Provide resources needed for the ISMS.	Budget, tools, external support, time allocation	Check whether identified actions have resources and dates.	Owner provides time and tools, but resource planning is informal.	Owner response	Partially conforming	Document resources required for open actions.
7.2	Support	Determine competence and retain supporting evidence.	Certificates; training; experience; competence matrix	Map evidence to assigned responsibilities.	Relevant certificates and experience exist but are scattered and not mapped.	Security+, Splunk, Per Scholas and experience records	Partially conforming	Create a competence register linked to responsibilities.
7.3	Support	Ensure people understand policy, contribution and consequences.	Awareness records; acknowledgements; briefing evidence	Confirm applicable requirements are understood.	Owner understands key requirements, but no formal awareness record exists.	Owner responses	Partially conforming	Complete and retain an annual self-briefing or acknowledgement.
7.4	Support	Define relevant internal and external security communications.	Communication plan; incident contacts; notification rules	Check what, when, with whom and by whom communication occurs.	Incident contacts and notification principles exist in draft policies only.	Project 5 policy pack	Partially conforming	Approve a concise communications matrix.
7.5	Support	Create, control, protect and update documented information.	Document register; versions; approvals; storage; change history	Sample ISMS documents for consistent control attributes.	Some controls exist but are inconsistent across documents.	Projects 1–5; owner response	Partially conforming	Create a controlled ISMS document register.
8.1	Operation	Plan, implement and control ISMS operating activities.	Operating procedures; schedules; completed records	Trace planned controls to recurring evidence.	Several controls operate, but implementation is not systematically tracked.	Owner response; Projects 3–5	Partially conforming	Create an ISMS operating calendar and evidence index.
8.2	Operation	Perform risk assessments at planned intervals and after significant change.	Review schedule; reassessment records; change triggers	Confirm assessments occur when scheduled or triggered.	Initial assessment exists; no recurring schedule has operated.	Project 3 risk register	Partially conforming	Approve annual and change-triggered reassessment dates.
8.3	Operation	Implement the risk-treatment plan and retain results.	Action tracker; evidence; residual-risk approval	Sample treatments for completion and effectiveness evidence.	Some controls operate, but treatments are not formally tracked to closure.	Owner response; Projects 3–5	Partially conforming	Track owner, due date, evidence, closure and residual risk.
9.1	Evaluation	Monitor, measure, analyze and evaluate ISMS performance.	Metrics; methods; results; reviews; actions	Recalculate metrics and trace actions from missed targets.	No formal security metrics process currently exists.	Owner response	Nonconforming	Create and review a monthly security dashboard.
9.2	Evaluation	Conduct objective internal audits at planned intervals.	Audit program; checklist; evidence; findings; follow-up	Check audit scope, objectivity, results and closure.	No prior internal-audit process exists; this project is an owner self-assessment.	Owner response; this workbook	Nonconforming	Schedule a future objective internal audit by a competent independent person.
9.3	Evaluation	Conduct management reviews of the ISMS.	Agenda; inputs; decisions; actions; attendance	Confirm required inputs are reviewed and outputs recorded.	No formal management reviews have been performed.	Owner response	Nonconforming	Perform and document an initial management review after approval.
10.1	Improvement	Continually improve ISMS suitability, adequacy and effectiveness.	Improvement log; trend reviews; completed actions	Trace improvements from identified need through verification.	Projects show improvement activity, but no recurring process exists.	Projects 1–6	Partially conforming	Maintain an improvement log and review results.
10.2	Improvement	Respond to nonconformities, address causes and verify corrective action.	CAPA log; root cause; actions; effectiveness evidence	Sample closed items for cause analysis and effectiveness review.	No operating corrective-action process currently exists.	Owner response	Nonconforming	Implement the corrective-action tracker in this workbook.

Selected Annex A Control Testing								
Controls selected in the Project 4 Statement of Applicability.								
Control	Control topic	Control objective	Evidence to request	Testing procedure	Current assessment	Evidence reviewed	Result	Recommended action
A.5.9	Inventory of information and associated assets	Maintain an inventory of relevant information, devices, accounts and services.	Asset, account and service inventories	Reconcile samples to current devices, accounts and providers.	Critical accounts and assets are known informally; no complete consolidated inventory exists.	Owner response; Projects 1–5	Partially conforming	Create consolidated asset and critical-account inventories.
A.5.15	Access control	Define and apply access based on business need.	Access rules; account inventory; reviews; exceptions	Sample critical accounts for owner, privilege, MFA and review.	Access is owner-controlled, but the inventory and periodic review evidence are incomplete.	Owner response; Project 5	Partially conforming	Complete the account inventory and six-month review.
A.5.19	Supplier relationships	Manage security risks arising from suppliers.	Supplier register; classification; reviews; agreements	Sample critical providers for data access, dependency and review evidence.	Suppliers are known, but formal security reviews are incomplete.	Owner response; Project 5	Partially conforming	Create the supplier register and complete initial reviews.
A.5.24	Incident management planning and preparation	Prepare roles, processes and resources for security incidents.	Approved incident policy; contacts; incident log; exercise results	Inspect readiness documents and trace one exercise or event.	An incident log exists and no events are recorded, but the policy is pending and no exercise evidence exists.	Owner response; Project 5	Partially conforming	Approve the policy and perform a tabletop exercise.
A.5.30	ICT readiness for business continuity	Plan technology recovery needed for business continuity.	Continuity steps; provider contacts; recovery tests	Trace critical services to recovery procedures and tests.	Continuity requirements are drafted; website migration testing remains incomplete.	Owner response; Project 5	Partially conforming	Complete website restoration testing and document results.
A.5.34	Privacy and protection of PII	Identify and apply privacy requirements for personal information.	Data inventory; privacy rules; retention; disclosure records	Trace customer information from collection to deletion.	Protective practices exist, but retention, passcode authorization and destruction evidence are inconsistent.	Owner response; Project 5	Partially conforming	Formalize retention and add authorization/destruction fields.
A.7.9	Security of assets off-premises	Protect devices and information outside controlled premises.	Custody log; transport and storage records; incident reports	Sample on-site and overnight repairs for documented custody.	Receipts contain some details, but no consistent custody log exists.	Owner response; Project 5	Partially conforming	Add custody fields to repair records.
A.8.1	User endpoint devices	Protect information stored on or accessed through endpoints.	Device baseline; encryption; updates; protection; wipe; backups	Inspect each business device against the approved baseline.	Most controls are enabled, but supporting evidence is not consolidated.	Owner response	Partially conforming	Create a device-security baseline and evidence record.
A.8.5	Secure authentication	Use secure authentication appropriate to access risk.	MFA, recovery methods, sessions, passwords, integrations	Inspect configurations for critical accounts and resolve gaps.	MFA is used on critical accounts, but password uniqueness, recovery methods, sessions and integrations have not been fully verified.	Owner response; Project 3	Partially conforming	Perform and document a complete critical-account review.
A.8.13	Information backup	Maintain and test backups according to business need.	Backup schedule; completion records; restoration results	Inspect backup status and reperform or observe restoration testing.	Business records have been recovered, but formal test evidence and website restoration testing are incomplete.	Owner response; Project 5	Partially conforming	Record restoration evidence and complete the website test.

Severity describes conformity impact. It is separate from information-security risk severity.									
Finding ID	Criteria	Condition	Potential effect	Evidence basis	Grade	Status	Owner	Required correction or action	Closure evidence
F-01	4.4	The ISMS documentation has been drafted, but no formally approved recurring governance cycle currently operates.	The ISMS may not be consistently implemented, evaluated or improved.	Owner response and Projects 1–5	Major nonconformity	Open	Richard Vincent	Approve the ISMS framework and establish the operating calendar.	Approved documents, calendar and first completed review records
F-02	5.2	The information security policy pack remains pending approval.	Security direction and responsibilities are not yet formally adopted.	Project 5 policy pack	Minor nonconformity	Open	Richard Vincent	Approve, date and communicate the policy pack.	Signed approval record and communication evidence
F-03	6.2	Security objectives exist informally but are not measurable or tracked.	Management cannot reliably determine whether intended security outcomes are achieved.	Owner response	Minor nonconformity	Open	Richard Vincent	Create a measurable objectives register.	Approved objectives, targets, dates and review results
F-04	7.5	Document controls are inconsistent across the ISMS artifacts.	Outdated or unapproved documents may be used.	Projects 1–5 and owner response	Minor nonconformity	Open	Richard Vincent	Create one controlled ISMS document register.	Register with owner, version, approval, storage and review data
F-05	8.3	Risk treatments are not formally tracked through evidence, closure and residual-risk approval.	Planned risk reduction may remain incomplete or unverified.	Project 3 and owner response	Minor nonconformity	Open	Richard Vincent	Complete treatment tracking fields and retain closure evidence.	Updated plan, evidence links and residual-risk decisions
F-06	9.1	No formal ISMS monitoring and measurement process exists.	Control failures and overdue actions may not be identified promptly.	Owner response	Minor nonconformity	Open	Richard Vincent	Implement a monthly security metrics review.	Metric definitions and first completed dashboard review
F-07	9.2	No prior planned, objective internal-audit process exists.	ISMS gaps may remain unidentified; owner self-review lacks independence.	Owner response	Minor nonconformity	Open	Richard Vincent	Schedule an objective audit by a competent independent person.	Approved audit program, auditor competence and completed report
F-08	9.3	No formal ISMS management review has been performed.	Management decisions, priorities and resources may not be documented.	Owner response	Minor nonconformity	Open	Richard Vincent	Conduct the initial management review after approval.	Agenda, required inputs, decisions and assigned actions
F-09	10.2	No operating corrective-action process exists.	Causes of nonconformities may recur and closure may not be verified.	Owner response	Minor nonconformity	Open	Richard Vincent	Use the corrective-action tracker and verify effectiveness.	Root-cause analysis, completed actions and effectiveness review
F-10	A.5.9 / A.8.5	No complete critical-account inventory or documented periodic access review exists.	Unknown recovery methods, sessions or integrations may permit unauthorized access.	Owner response	Minor nonconformity	Open	Richard Vincent	Create the inventory and perform the initial access review.	Completed inventory and dated review record
F-11	A.7.9 / A.5.34	Customer-device custody and temporary-passcode destruction are not consistently evidenced.	Loss, unauthorized access or disputes may be harder to prevent or investigate.	Owner response	Minor nonconformity	Open	Richard Vincent	Add custody, authorization and destruction fields to repair records.	Updated form and sample completed records
F-12	A.5.19	Critical suppliers have not completed a consistent documented security review.	Supplier compromise or outage risks may be inadequately treated.	Owner response	Minor nonconformity	Open	Richard Vincent	Create the register and complete initial supplier reviews.	Supplier register, review results and treatment decisions
F-13	A.8.1	Business-device controls are not consolidated into a verified baseline record.	Missing or failed endpoint controls may remain undetected.	Owner response	Observation	Open	Richard Vincent	Document and verify the baseline for each business device.	Completed device-security record and supporting screenshots/reports
F-14	A.8.13	Formal restoration-test evidence and the post-migration website test are incomplete.	Backups may fail to meet recovery needs when required.	Owner response	Minor nonconformity	Open	Richard Vincent	Complete and document restoration testing.	Dated restoration results, issues and corrective actions

Corrective-Action Tracker									
Closure requires evidence and an effectiveness review. Changing status updates the overview counts.									
Finding ID	Criteria	Corrective action	Owner	Target date	Status	Required closure evidence	Completion date	Effectiveness review	Verified by
F-01	4.4	Approve the ISMS framework and establish the operating calendar.	Richard Vincent	09/27/26	Not started	Approved documents, calendar and first completed review records			
F-02	5.2	Approve, date and communicate the policy pack.	Richard Vincent	10/13/26		Signed approval record and communication evidence			
F-03	6.2	Create a measurable objectives register.	Richard Vincent	10/13/26		Approved objectives, targets, dates and review results			
F-04	7.5	Create one controlled ISMS document register.	Richard Vincent	10/13/26		Register with owner, version, approval, storage and review data			
F-05	8.3	Complete treatment tracking fields and retain closure evidence.	Richard Vincent	10/13/26		Updated plan, evidence links and residual-risk decisions			
F-06	9.1	Implement a monthly security metrics review.	Richard Vincent	10/13/26	Not started	Metric definitions and first completed dashboard review			
F-07	9.2	Schedule an objective audit by a competent independent person.	Richard Vincent	10/13/26		Approved audit program, auditor competence and completed report			
F-08	9.3	Conduct the initial management review after approval.	Richard Vincent	10/13/26		Agenda, required inputs, decisions and assigned actions			
F-09	10.2	Use the corrective-action tracker and verify effectiveness.	Richard Vincent	10/13/26		Root-cause analysis, completed actions and effectiveness review			
F-10	A.5.9 / A.8.5	Create the inventory and perform the initial access review.	Richard Vincent	10/13/26		Completed inventory and dated review record			
F-11	A.7.9 / A.5.34	Add custody, authorization and destruction fields to repair records.	Richard Vincent	10/13/26	Not started	Updated form and sample completed records			
F-12	A.5.19	Create the register and complete initial supplier reviews.	Richard Vincent	10/13/26		Supplier register, review results and treatment decisions			
F-13	A.8.1	Document and verify the baseline for each business device.	Richard Vincent	10/13/26		Completed device-security record and supporting screenshots/reports			
F-14	A.8.13	Complete and document restoration testing.	Richard Vincent	10/13/26		Dated restoration results, issues and corrective actions			

Method and Ratings

Use this workbook as a readiness assessment and action tracker. It is not evidence of ISO certification.

Assessment result	Definition
Conforming	The requirement is satisfied with sufficient, appropriate and current evidence.
Partially conforming	Some design or implementation exists, but evidence or operation is incomplete.
Nonconforming	The requirement is not satisfied or a required process is absent.
Not applicable	The requirement genuinely does not apply and the justification is documented.
Not tested	The assessment did not obtain enough evidence to reach a conclusion.

Finding grade	Definition
Observation	An improvement opportunity without a confirmed nonconformity.
Minor nonconformity	An isolated or limited failure that does not by itself indicate overall ISMS breakdown.
Major nonconformity	A missing required process or systemic failure that threatens the ISMS's ability to achieve intended results.

Workflow	1. Confirm the audit criterion and population. 2. Request evidence and evaluate its sufficiency, appropriateness and period relevance. 3. Test design and current implementation. Do not infer operation from a policy alone. 4. Record the result and condition using only supported facts. 5. Assign corrective action, owner, date and required closure evidence. 6. Verify effectiveness before closing a nonconformity.
----------	--

Important limitations	This is an owner-led point-in-time self-assessment, not an independent internal audit. Draft documents show readiness progress but do not prove approval or operating effectiveness. Control and clause text is paraphrased. Consult the licensed ISO/IEC 27001:2022 standard for authoritative The workbook does not claim ISO certification or complete conformity.
-----------------------	---